

Beware! These Are Some Major Active Directory Threats Lurking in Your Network

 fidelissecurity.com/threatgeek/active-directory-security/major-active-directory-threats

Sarika Sharma

May 7, 2024



Key Takeaways

- Active Directory is a prime attack target, with common techniques including brute force attacks, Kerberos abuse, lateral movement, and domain controller compromise; brute force being one of the most widely used methods globally.
- Many successful ransomware attacks begin with Active Directory misconfigurations and other security weaknesses, enabling attackers to escalate privileges and spread rapidly across the network.
- The most exploited Active Directory vulnerabilities include weak passwords, excessive privileges, legacy authentication protocols, and misconfigured Kerberos settings.
- Many Active Directory attacks are preventable when these vulnerabilities are addressed early through focused hardening.
- Effective AD threat mitigation relies on least privilege access, multi-factor authentication (MFA), strong password policies, and continuous monitoring.

95% of Fortune 1000 organizations^[1] use Active Directory (AD) to organize their IT systems. This statistic emphasizes the relevance of AD in modern enterprise networks. AD, as a centralized database including user accounts, group objects, workstation objects, security information, and much more, is critical for managing and securing IT resources.

However, the very capabilities that make [Active Directory](#) so important, also make it an ideal target for cyber criminals. In enterprise environments, proper Active Directory hardening – such as enforcing least privilege, robust password policies, and network segmentation – is essential to [reduce the attack surface](#) and close common vulnerabilities.

Attackers often look for simple weaknesses that are easy to exploit, such as excessive user permissions, weak password requirements, outdated authentication methods, and other Active Directory misconfigurations that can provide a foothold into the environment.

In this blog, we'll look at the top Active Directory threats that organizations should be aware of, plus best practices for active directory hardening in enterprise environments, step-by-step hardening checklists to close common vulnerabilities, cloud vs on-premises hardening solution comparisons, network audit steps for hidden threats, automation with [popular security platforms](#), and endpoint protection integration strategies.

What is Active Directory Security?

Active Directory (AD) is the heart of your IT infrastructure, controlling who has access to what. If attackers gain access, they can steal data, take over accounts, and shut down activities. That is why is more than simply an IT task; it is a business requirement.

What's at Stake?

- **Domain Controllers** – The brain of AD; if hacked, attackers own your network.
- **User Accounts** – Weak credentials? That's an open door for cybercriminals.
- **Group Policies** – Poorly configured settings can [expose sensitive data](#).

How to Lock It Down

- **Enforce Multi-Factor Authentication (MFA)** – No easy logins for attackers.
- **Use Strong Passwords & Least Privilege Access** – Limit damage from breaches.
- **Monitor & Audit Regularly** – Spot suspicious activity before it's too late.

Active Directory Security Framework

Controls access to applications and data

Includes domain controllers and user accounts

Implements protections like MFA and passwords

Ensures resilience against threats



8 Major Active Directory Threats to Watch Out For

Let's dive into 8 important Active Directory threats businesses should be aware of and practical measures to mitigate them.

1. Brute Force Attacks

[Brute force attacks](#) and password cracking are among the most common Active Directory threats. Attackers often use automated tools to crack passwords and exploit weak password policies, which allows them to get their hands on unauthorized access to sensitive data and systems within the network.

To stand strong against this threat, it is important to create strict password policies that require strong, complex passwords. This includes establishing minimum password length, use of special characters, and timely updating passwords. And, if you implement multi-factor authentication (MFA), it will act as an extra layer to the authentication process. Enforce account lockout policies after failed login attempts and audit privileged accounts regularly to detect hidden threats.

Password managers can also be an extremely helpful tool to protect you against password-based threats. By securely storing and generating strong, unique passwords for each user, password managers can help limit the risks of password breaches.

2. Lateral Movement and Privilege Escalation

Once the attackers get access to your network using brute force, they can use [lateral movement](#) techniques to spread throughout the domain and boost their privileges. This will give them access to sensitive network locations and then they can steal valuable data or disrupt critical systems.

To lower the risk of lateral movement and [privilege escalation](#), apply the principle of least privilege and regularly monitor user behavior on the network. This includes assessing and upgrading user permissions regularly, restricting domain admins group access, implementing the principle of least privilege, and using tools like [Fidelis Elevate](#)® for detecting and responding to suspicious activities and ensuring complete active directory protection.

Endpoint agents feed telemetry (credential dumps, process injection) directly into AD monitoring. Fidelis XDR correlates [EDR](#) alerts with AD authentication failures to block lateral movement across hybrid environments.

Integrate endpoint protection platforms to enhance strategies across on-premises and cloud setups.

3. Active Directory Ransomware

[Active Directory ransomware](#) attacks have become a growing menace in recent years. These attacks encrypt vital files and data on the network, and in exchange for giving back the control and decryption key, the attackers demand money.

Well, to limit the impact of ransomware attacks, it's quite necessary to maintain regular backups of your data and systems. This will ensure immediate restoration of your data in the case of a [ransomware attack](#), and it sure will minimize the damage to business operations.

Furthermore, keeping your software and operating systems up to date is crucial, as many ransomware attacks use known vulnerabilities. By patching and updating your systems, you will dramatically lower the likelihood of a successful ransomware attack.

In addition to all that, you should consider investing in anti-ransomware tools and solutions, to provide an extra layer of protection.

Watch Our Expert-Led Webinar

Safeguarding Active Directory in the Era of Cyber Threats

- Top Active Directory threats
- Learn how attackers gain access and how to prevent it
- Proactive strategies to strengthen your defenses

[Watch On-Demand Now](#)

The banner features the Fidelis Security logo in the top left corner, with the tagline "#1 in Proactive Cyber Defense". The main title "Crack the Code: Safeguarding Active Directory in the Era of Cyber Threats" is displayed in white and orange text. Below the title is a prominent orange "Watch Now" button. At the bottom, five speakers are listed with their headshots and titles: Rami Mizrahi (VP, Engineering, Fidelis Security), Paul Girardi (Cybersecurity Advisor, Fidelis Security), Mike Hoffman (Cofounder and CEO, SNOKE CONNECT), Robert Fuchs (VP International Services, Fidelis Security), and Nick Copeland (Senior System Engineer, Fidelis Security).

4. Kerberos Attacks

Kerberos is a crucial authentication protocol used in Active Directory yet it's not immune to attacks. [Kerberos attacks](#), such as Kerberos replay attacks, have the potential to weaken the authentication process, which allows attackers to gain unauthorized network access.

Now the question arises, how to fight against it?

Well, to prevent Kerberos attacks, you need to build secure Kerberos configurations—including restricting kerberos service tickets—and continuously monitor for any suspicious activity. This includes assessing and upgrading Kerberos settings regularly, as well as detecting AD attacks and responding to potential threats. Automate hardening tasks via group policy objects (GPOs) and platforms like Microsoft or Fidelis XDR.

5. Domain Controller Compromise

Domain controllers are considered the heart of Active Directory. It handles the user accounts and access permissions. If your domain controller gets compromised, then attackers can easily get unrestricted access to the whole network.

To avoid domain controller compromise, secure domain controllers with read only domain controllers (RODCs), network segmentation, and restricted physical security. Deploy strong security measures such as safe boot configurations and regular monitoring for suspicious activities. By doing so, you can reduce the chances of a successful attack against your Active Directory.

6. User Domain Threats

While you might be focused on external threats, do not ignore [insider threats](#) and social engineering attempts. These types of attacks usually involve trusted users or staff members, making it more difficult to detect and mitigate.

To address such threats, again you must have strong access controls, actively monitor user activities, and regularly provide security awareness training to your employees. This helps to educate your employees on the newest [social engineering](#) techniques out there and gives them the ability to detect and report suspicious conduct. Limit service accounts and group managed service accounts to essential permissions only.

7. DNS and DHCP Attacks

As you know, DNS and DHCP are important infrastructure components of Active Directory, and if they are immune to threats then it can interrupt network operations and open a backdoor for attackers.

To defend your system against these attacks, you need to implement secure configurations and monitor activities regularly. In addition to those you can deploy solutions such as Fidelis' XDR platform that detects and quickly responds to potential threats safeguarding your Active Directory. Disable lightweight directory access protocol (LDAP) signing where unnecessary and segment the ad environment.

8. Authentication Bypass

These attacks make use of [vulnerabilities](#) in the authentication process to gain unauthorized access to the network. These types of attacks can be especially difficult to identify and fight against as they often bypass traditional security measures.

To [defend against authentication bypass attacks](#), you should develop multi-factor authentication and advanced audit policy for compromised accounts.

Active Directory Risks Assessment: Identifying Vulnerabilities

Before we get into the specifics, it's important to understand the significance of doing an extensive [Active Directory risk assessment](#). This approach involves thoroughly assessing your AD environment to find vulnerabilities, configuration weaknesses, and Active Directory misconfigurations that attackers could exploit. Common examples include overprivileged accounts, poorly managed service accounts, and insecure Group Policy settings.

- Review group policy objects and user/computer objects.
- Scan domain controllers for excessive privileges.
- Test access rights via penetration tools.
- Check security posture with tools like [Fidelis Active Directory Intercept](#).

Active Directory Risk Assessment



Even seemingly minor configuration issues can create opportunities for attackers. If left unaddressed, Active Directory misconfigurations can lead to unauthorized access, privilege escalation, lateral movement, and, in some cases, complete domain compromise.

By conducting a [comprehensive risk assessment](#), you'll better understand the Active Directory risks of your organization and can design a specific security strategy to address them.

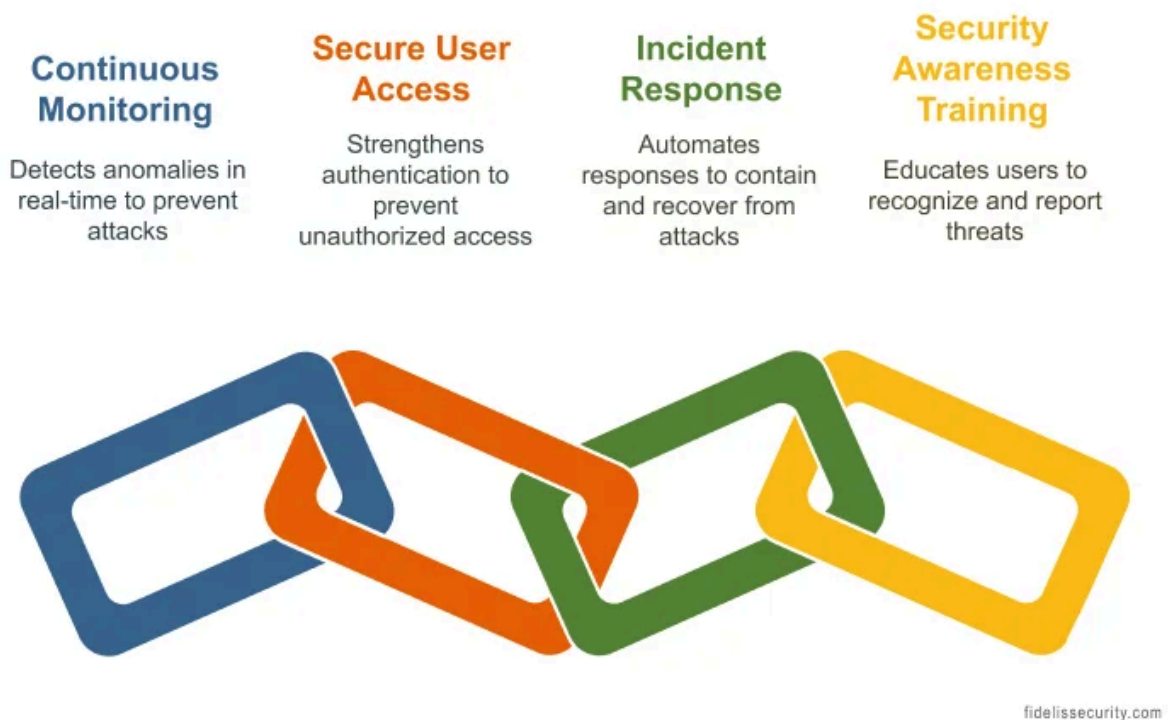
From Threats to Defense: Safeguarding Your Active Directory

Understanding the risks related to Active Directory is only the beginning; safeguarding it is where the real war begins. As we know, AD serves as the major hub for access control, if breached, attackers can obtain credentials, escalate privileges, and gain complete control

of your network. However, with proper strategy—including this [hardening active directory checklist](#)—you can keep ahead of emerging risks.

Not all vulnerabilities carry the same level of risk. Organizations should prioritize issues that affect domain controllers, privileged accounts, and authentication systems first, as these can have the greatest impact on business operations if compromised.

Protect Your Active Directory



1. Continuous Monitoring & Threat Detection

Cybercriminals exploit blind spots in AD security. Real-time monitoring helps detect suspicious activity before it spirals out of control. Deploy advanced tools to track authentication patterns, privilege escalations, and unusual logins.

Fidelis Elevate[®], unified XDR platform, enhances security by using [behavioral analytics](#) to detect and stop threats before they spread.

2. Secure User Access & Multi Factor Authentication

Weak authentication is an open door for attackers. Strengthen security with MFA to block credential-based attacks. AD is complex, but least privilege access policies ensure users and admins only have the minimum access needed – [reducing the risk of insider threats](#) and privilege escalation. Compare on-premises (e.g., RODCs) vs. cloud (Azure AD hardening) for tailored setups.

3. Proactive Incident Response

When an attack happens, response time is everything. A well-defined incident response plan outlines how to contain, eradicate, and recover from threats. [Automate responses](#) with security orchestration tools to lock down compromised accounts, cut off malicious sessions, and prevent attackers from moving deeper into your network.

4. Regular Security Awareness Training

Users are often the weakest link in security. Conduct simulated phishing attacks to test employees' awareness and reinforce best practices. Educate staff on social engineering tactics so they can recognize and report suspicious activities, [reducing the risk of credential theft](#)

By transitioning from recognizing threats to implementing robust security measures, you can safeguard your Active Directory from even the most sophisticated cyber threats.

Conclusion: Safeguarding Your Active Directory

To recap, threats to Active Directory are diverse and continually evolving. However, if you understand these primary dangers and execute security policies properly—using the complete step-by-step active directory hardening checklist outlined above—you can minimize the likelihood of a successful attack while simultaneously preserving critical digital assets.

At [Fidelis Security](#), we understand the critical role that Active Directory plays in enterprise networks. We're committed to guiding organizations through the complexities of cybersecurity and protecting them from Active Directory threats. Whether you want to strengthen your defenses or stay ahead of emerging risks, we have you covered.

Fidelis Active Directory Intercept

Defend your AD infrastructure against advanced attacks such as DCSync, DCShadow, Brute-force Authentication, DPAPI, Kerberoasting, LLMNR Poisoning and more!

[Read the Datasheet](#)

[Book a Demo Now!](#)



Frequently Asked Questions

What are the scenarios for Active Directory disaster?

- Domain controller failures, where critical authentication services become unavailable.
- Ransomware attacks, which encrypt AD databases, leading to operational shutdowns.
- Privilege escalations, which allow attackers to gain unauthorized access and manipulate user roles.
- Misconfigurations in Group Policies or replication settings can lead to security gaps and performance issues.
- Accidental deletions of organizational units or critical accounts.

How do I check Active Directory security?

What happens if Active Directory is compromised?

Citations:

1. [^https://www.microsoft.com/en-us/download/details.aspx?id=36391](https://www.microsoft.com/en-us/download/details.aspx?id=36391)